

a one-page checklist from The Farah Stack

Before your agent goes live

Ten checks I run before an AI agent touches real users, real data or real money. Print it, tick it, keep it next to the deploy button.

- 1 Egress allowlist, not hope**
Deny by default. The agent reaches only the hosts it needs, and you can list them.

- 2 A budget cap per run**
Tokens, tool calls and wall-clock time, each with a hard stop that actually stops it.

- 3 A kill switch you've actually pulled**
Tested in staging this month, not just "configured". Someone besides you knows where it is.

- 4 A human who gets paged**
A named person and a short runbook for when it goes sideways at 2am.

- 5 Least-privilege, short-lived credentials**
Scoped to the task. "Admin, just for now" is admin forever.

- 6 Tools written down**
Which tools it may call, with which arguments. Anything else is refused, not improvised.

- 7 Untrusted input stays data**
Web pages, emails and tool output never become instructions. Try a prompt-injection test on purpose.

- 8 A human approves anything irreversible**
Send, delete, pay, merge, publish: the agent proposes, a person confirms.

- 9 Logs you can replay**
Every prompt, tool call and result under one run id, so "what did it do?" has an answer.

- 10 Evals before and after every change**
A fixed test set that runs in CI. A new model or prompt ships only if it still passes.

what works: boundaries the model can't argue with.